OPEN-SOURCE INTELLIGENCE EXERCISES

OPEN-SOURCE INTELLIGENCE (OSINT)

OSINT je obaveštajna delatost gde se javno dostupni podaci koriste u svrhu prikupljanja informacija o nekome/nečemu. Delatnost je prepoznata i od strane institucija i definisana zakonskim aktima. Na primer, američka vlada (US Department of Defense - NATIONAL DEFENSE AUTHORIZATION ACT (2006)) ga definiše na sledeći način:

1. Open-source intelligence (OSINT) is intelligence that is produced from publicly available information and is collected, exploited, and disseminated in a timely manner to an appropriate for the purpose of addressing a specific intelligence requirement.
2. With the Information Revolution, the amount, significance, and accessibility of open-source information has expanded significantly, but the intelligence community has not expanded its exploitation efforts and systems to produce open-source intelligence.
3. The production of open-source intelligence is a valuable intelligence discipline that must be integrated into intelligence tasking, collection, processing, exploitation, and dissemination to ensure that United States policymakers are fully and completely informed.

Ideja vežbe jeste da osvesti studente da postoji čitava disciplina koja se tiče otkrivanja podataka iz javnih izvora. Kako podaci mogu biti iskorišteni za napad na neki sistem, vrlo je bitno i o tome voditi računa. Pri tome, pretnja ne mora biti vrlo jasno vidljiva, poput slučaja kada je slučajno otkrivena lozinka. Može biti i podmuklija. Recimo, pronađeni podaci mogu biti iskorišteni za socijalni inženjering.

Na prethodnim terminima ste čak imali prilike da se oprobate u tome. U okviru Juice Shop platforme je jedan od zadataka bio da se pronađe odgovor na Bjoernovo bezbednosno pitanje, koji je on slučajno učinio javno dostupnim. A popričali smo i o ostavljanju tajni (lozinki, tokena…) na git repozitorijumu ☺

EXAMPLE 1 – CONDUCTING PASSIVE RECONNAISSANCE WITH GOOGLE DORKS

SUGGESTED READINGS

- https://resources.infosecinstitute.com/penetration-testing-intelligence-gathering/

TUTORIAL

The Google Hacking Database (GHDB) is a categorized index of Internet search engine queries designed to uncover interesting, and usually sensitive, information made publicly available on the Internet. In most cases, this information was never meant to be made public but due to any number of factors this information was linked in a web document that was crawled by a search engine that subsequently followed that link and indexed the sensitive information.

Go to the https://www.exploit-db.com/google-hacking-database and try out the queries for your favorite website.

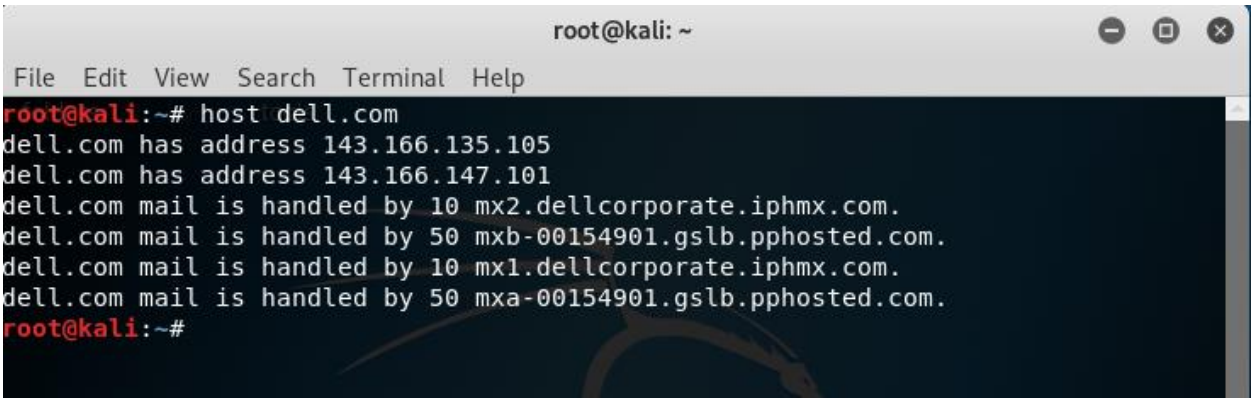
EXAMPLE 2 – CONDUCTING PASSIVE RECONNAISSANCE WITH SHODAN

TUTORIAL

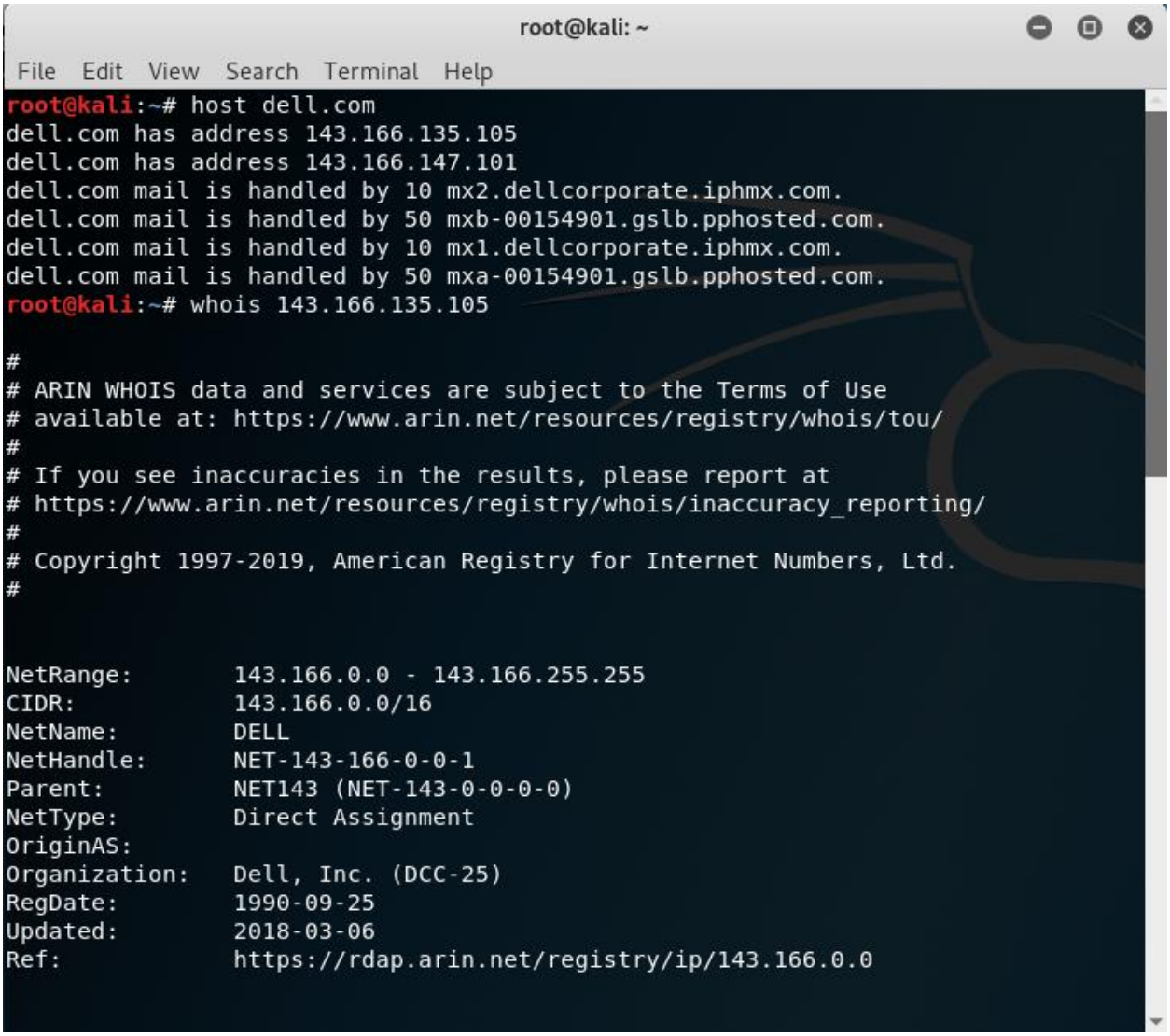
Shodan is a search engine for Internet-connected devices. Web search engines, such as Google and Bing, are great for finding websites. But what if you're interested in measuring which countries are becoming more connected? Or

if you want to know which version of Microsoft IIS is the most popular? Or you want to find the control servers for malware? Maybe a new vulnerability came out and you want to see how many hosts it could affect? Traditional web search engines don't let you answer those questions. Shodan gathers information about all devices directly connected to the Internet. If a device is directly hooked up to the Internet, then Shodan queries it for various publicly-available information. The types of devices that are indexed can vary tremendously: ranging from small desktops up to nuclear power plants and everything in between. So, what does Shodan index then? The bulk of the data is taken from banners, which are metadata about a software that's running on a device. This can be information about the server software, what options the service supports, a welcome message or anything else that the client would like to know before interacting with the server.

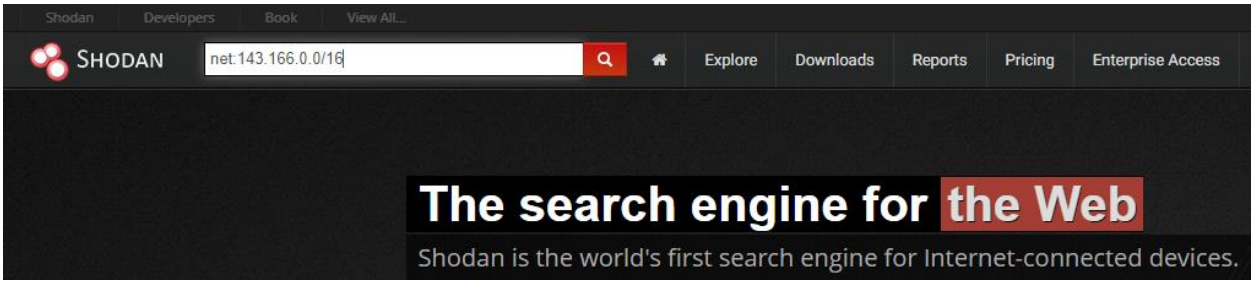
In the following example, we'll perform some basic reconnaissance activity against Dell. We'll start by finding an IP address associated with a website we know belongs to Dell and this example we use dell.com.

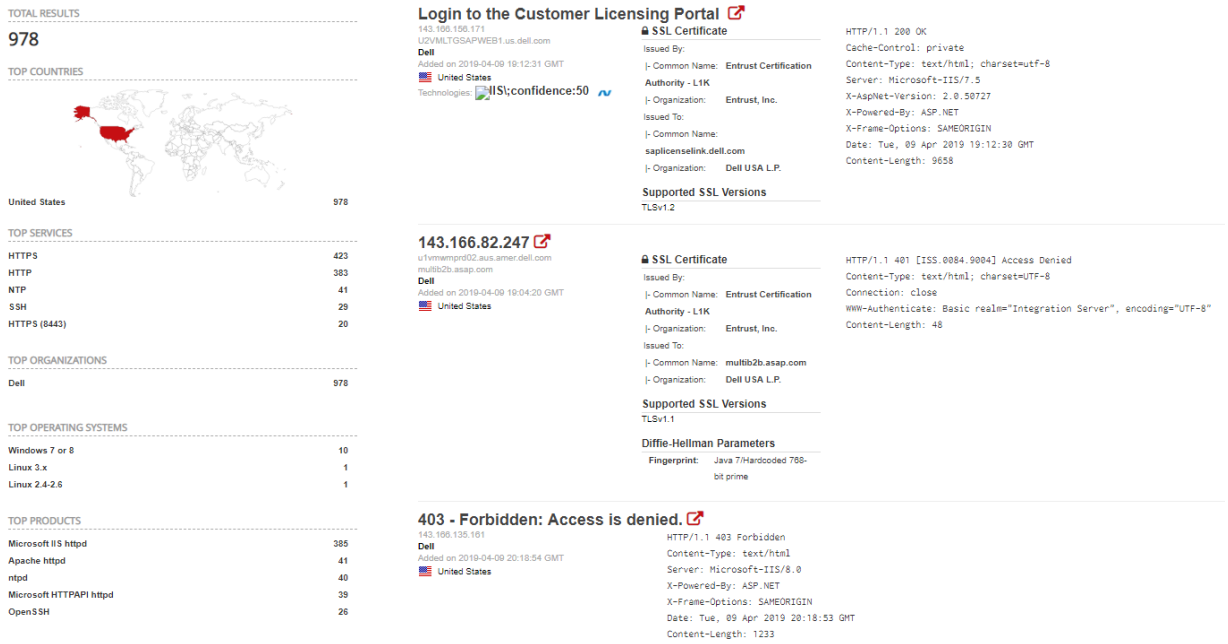


You can see that when resolve IP addresses for this domain name, we get back several results. We'll copy the first example and perform whois: query to get additional information. We can see that this IP address is assigned to a network range and this network range has been assigned to Dell Inc.

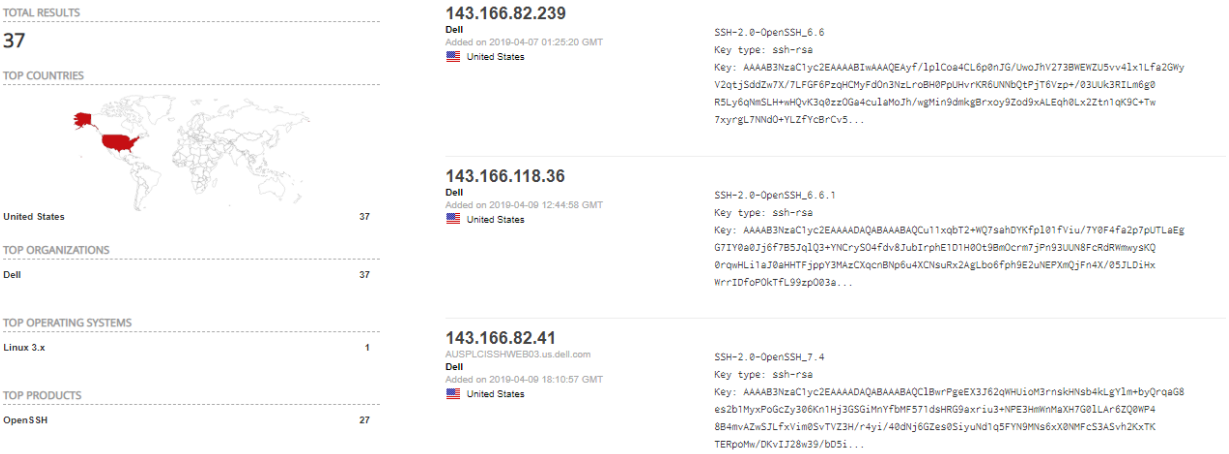


We'll copy this network range and we'll use a tool called shodan.io. Shodan regularly scans the internet for publicly accessible services and archives all of the results, along with fingerprinting on those services, in a searchable format. We will limit our search to addresses and network range belonging to Dell.



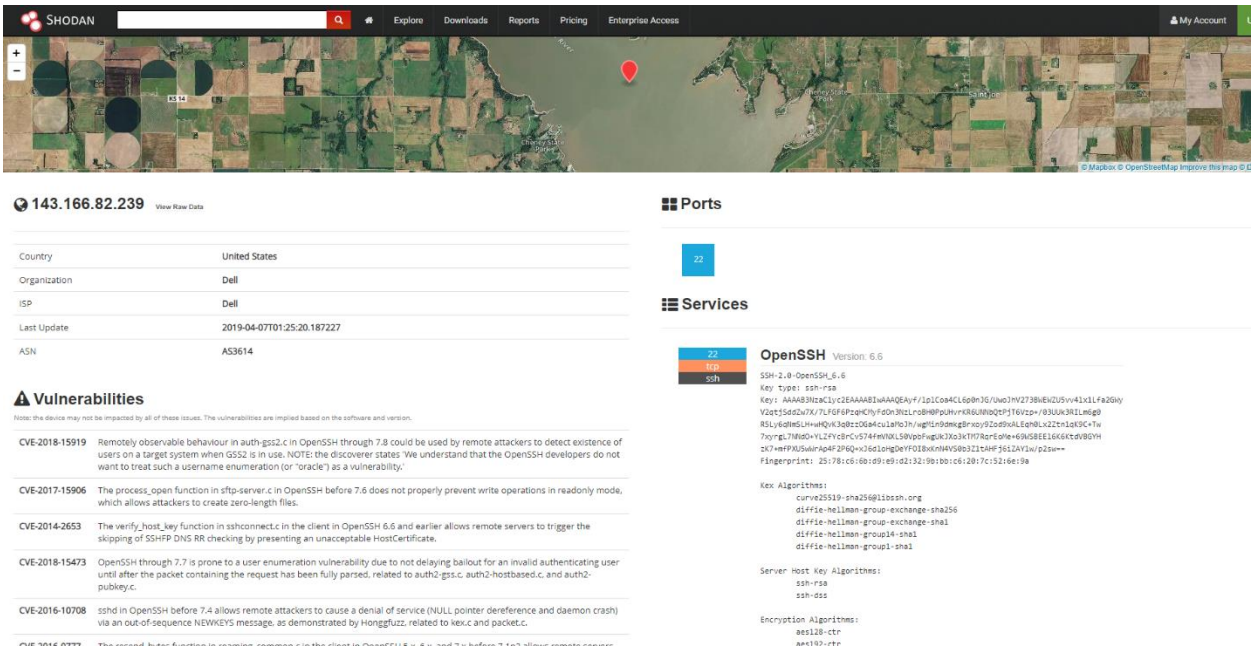


We can see that there's a total of 978 services that Shodan is currently aware of. Shodan gives us a list of the most common services in this range including http, https, ssh, and vp unrelated services. We can also see operating systems that are available on these ranges and products that might be accessible. If we are interested in systems with ssh, we can go ahead and click on ssh and it will add a filter to limit our results to services in the Dell range that have ssh available.



We can click on any of the IP addresses and it will bring up additional information including host name, when it was last scanned, geographic information if it's available, as well as accessible ports on the system. So, in this case we can see there is port 22, or ssh, and port 443 and if we look at these services we see Shodan has kept fingerprinting information about these services which can be useful. In this case, we were able to gain a list of services that are accessible in a target network without having to send a single packet to that target network.

ISSES



ZADACI

Uz ovaj document na canvasu možete naći i folder sa pojedinačnim "capture the flag" zadacima. Po uzoru na to kako je demonstrirano na vežbama za prva tri zadatka, pokušajte da pronađete rešenja zadataka za ostatak. Svako od studenata bi trebalo da reši po dva zadatka i da ih dokumentuje. Srećan lov ☺

ISSES